

CHALLENGE #21: Bookmarklet Write-up.

Bookmarklet

Easy

Web Exploitation

picoCTF 2024

obfuscation

browser_webshell_solvable

browser

AUTHOR: JEFFERY JOHN

Description

Why search for the flag when I can make a bookmarklet to print it for me?

Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.

Its current status is:

NOT_RUNNING

Launch Instance

63,134 users solved

1

2

3

A bookmarklet is a bookmark that runs JavaScript instead of loading a webpage.

1

2

3

What happens when you click a bookmarklet?

1

2

3

Web browsers have other ways to run JavaScript too.

picoCTF{FLAG}

Solving Process:

The page contained a text area displaying JavaScript code that appeared to include an encrypted flag. The challenge description hinted that the solution involved creating a **bookmark**, suggesting that the JavaScript code might be intended to run as a **bookmarklet**.

CYBSEC

(1697) Inje...

picoCTF - p...

ALIF4/BAT...

UFI Exploit...

CYBSEC-CI...

All labs | W...

CHALLENGE...

Facebook

picoCTF - p...

Not secure titan.picoctf.net:59965

Apps PL REPORTING NLP RESEARCH APPSDEV2 USC LAB SYSTEM CYBSEC WEB LEARNING PYTHON LEARNING Mobile WiFi

picoCTF

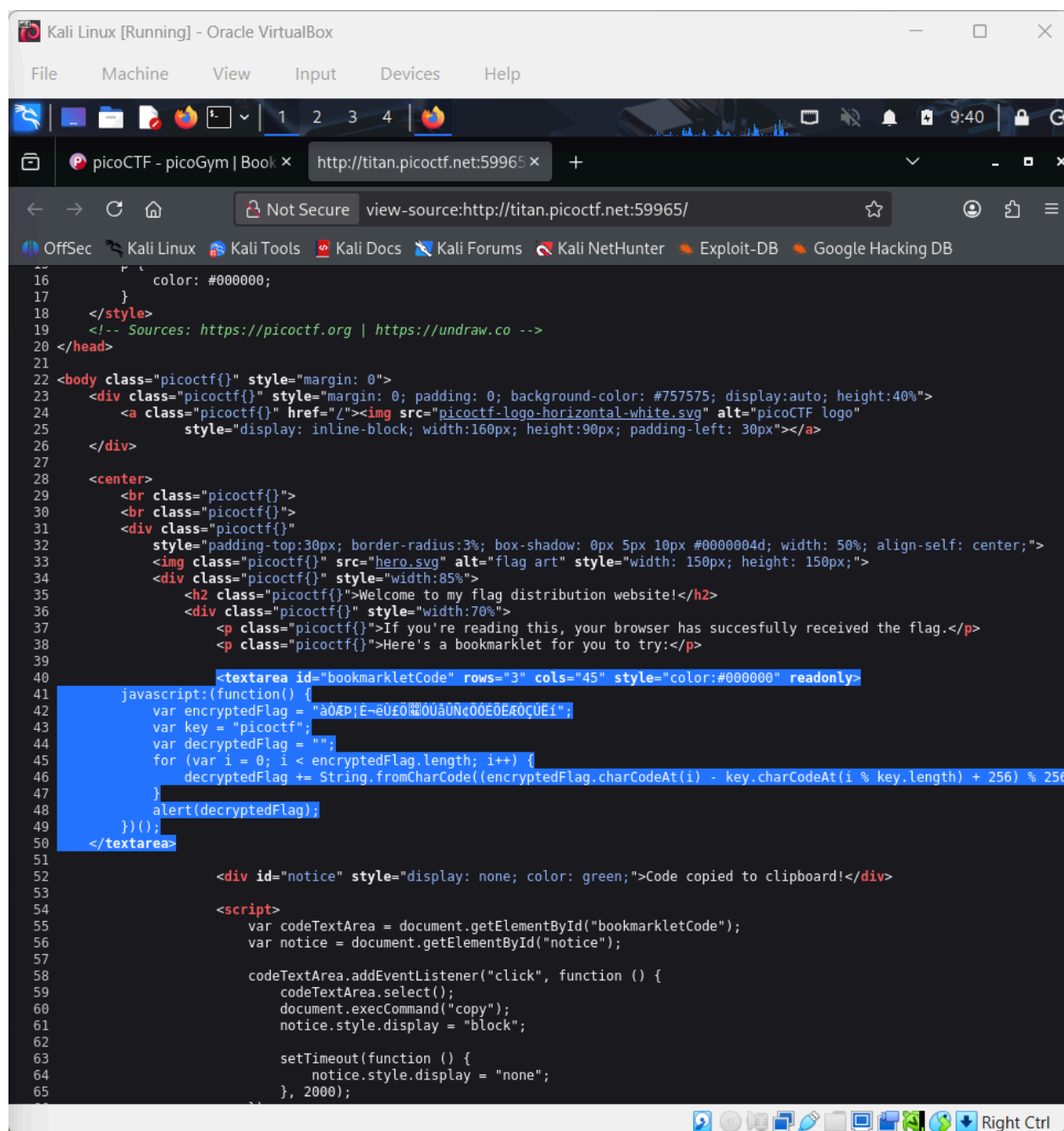
welcome to my flag distribution website!

If you're reading this, your browser has successfully received the flag.

Here's a bookmarklet for you to try:

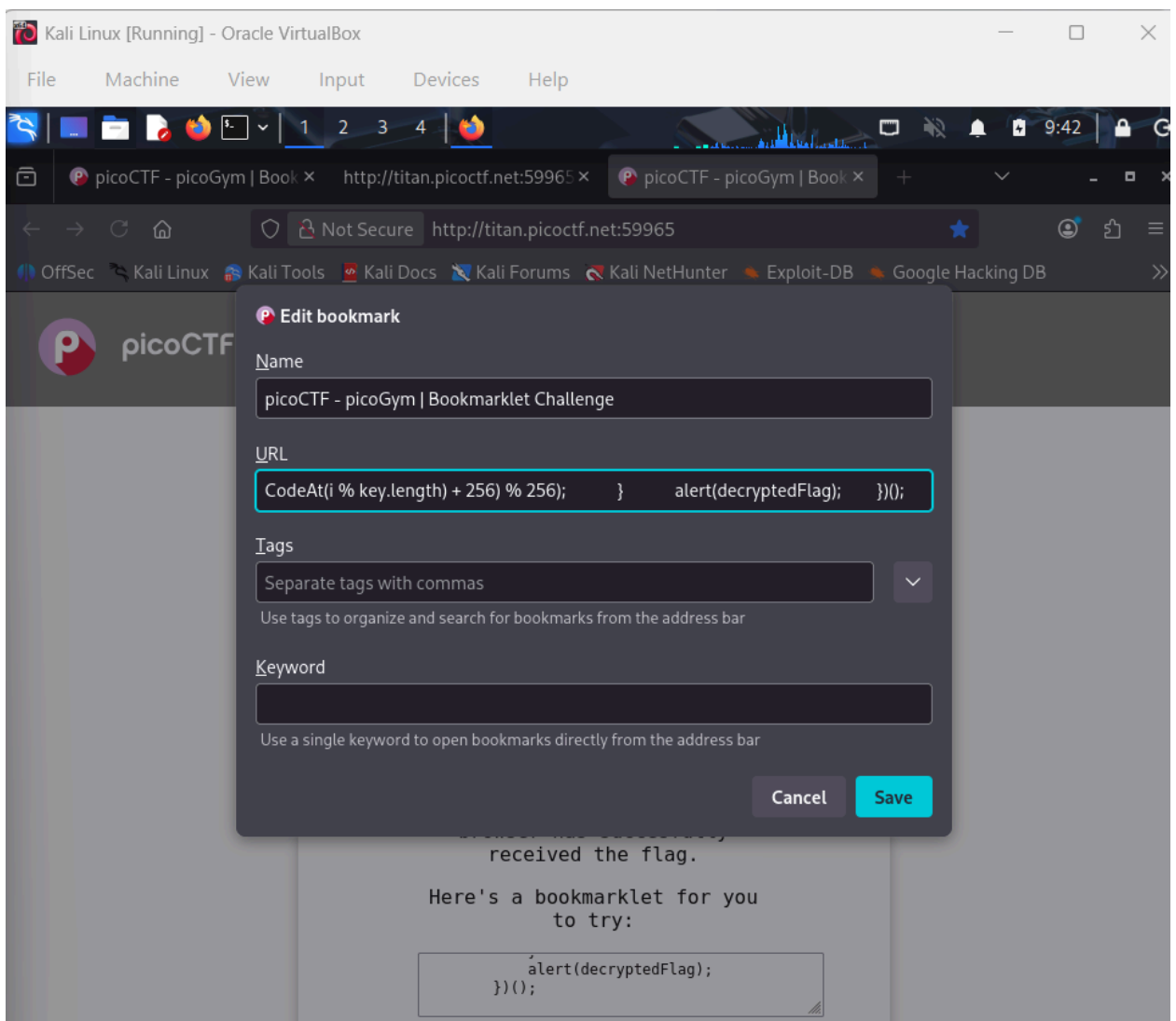
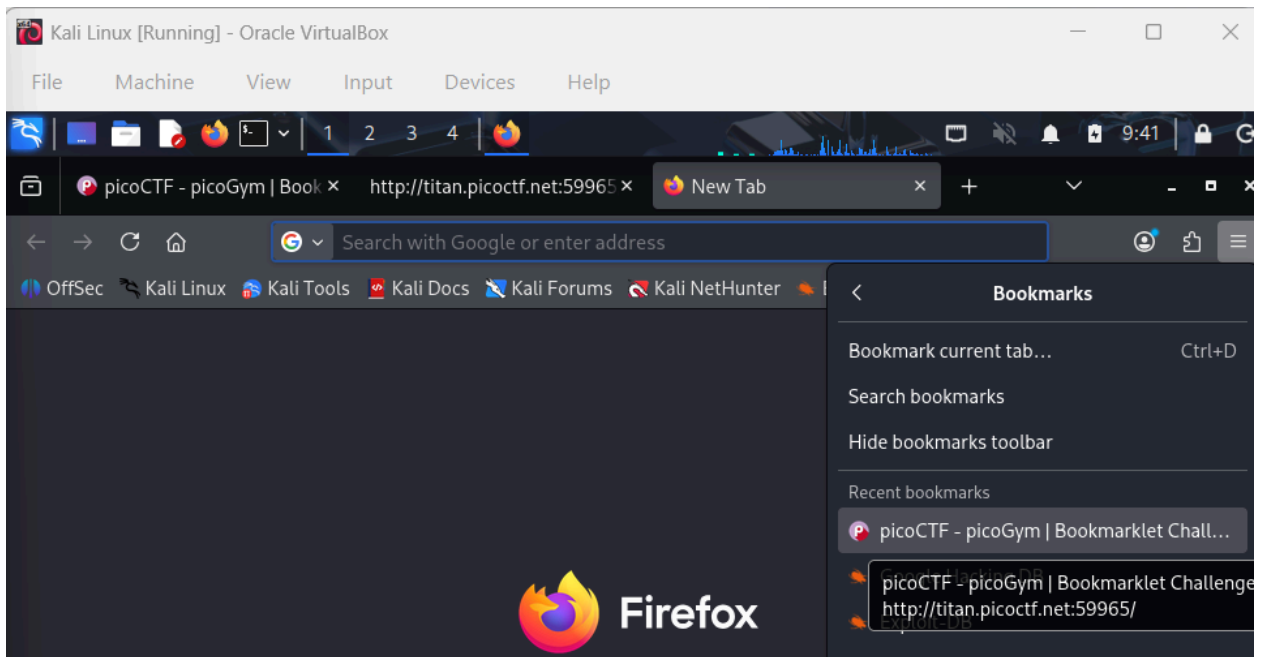
```
javascript:(function() {
  var encryptedFlag = "aAdb|E-00e0B00A00H000e0A0C0E1";
  var key = "picoctf";
  var decryptedFlag = "";
  for (var i = 0; i < encryptedFlag.length; i++) {
    decryptedFlag += String.fromCharCode(encryptedFlag.charCodeAt(i) - key.charCodeAt(i % key.length) + 256) % 256);
  }
  alert(decryptedFlag);
})();
```

To understand how the page worked, the page source was inspected. In the HTML code, it was observed that the JavaScript displayed in the text area started with the prefix **javascript:**, which indicates that the code is meant to run as a bookmarklet when triggered from a browser bookmark.

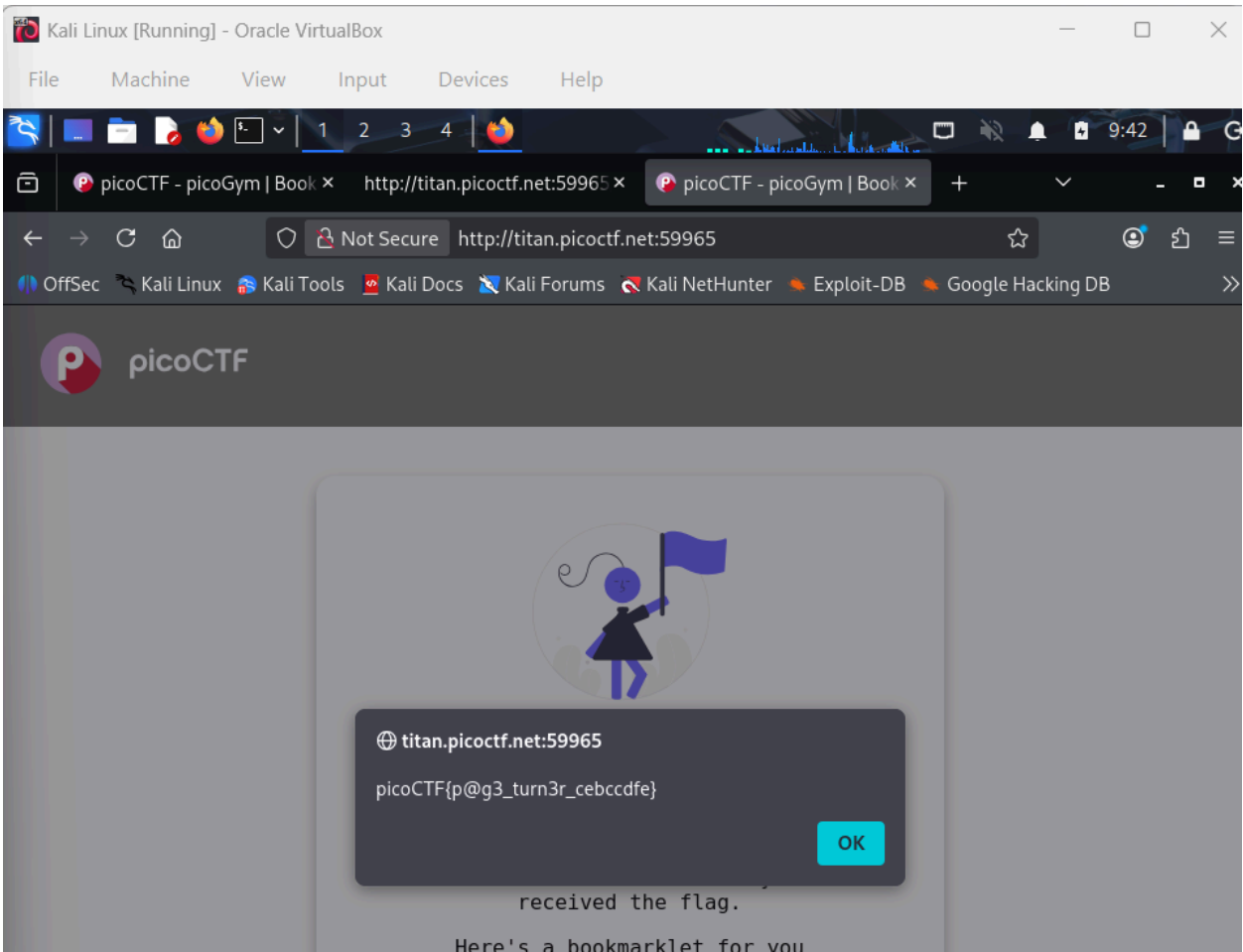


Further examination of the code showed that it contained several components: an **encrypted flag**, a **decryption key**, and a **loop that decrypted the flag**. The script also included a function that would display the decrypted flag through a **popup message** once the code was executed.

To execute the code, the website was first bookmarked using the browser's bookmark feature. After saving the bookmark, the bookmark settings were opened and the URL of the bookmark was edited. The original website URL was replaced with the JavaScript code copied from the text area.



Once the bookmark was updated, clicking the bookmark triggered the JavaScript bookmarklet. When executed, the script ran in the browser, decrypted the encoded value, and displayed the flag in a popup window.



Bookmarklet

Easy Web Exploitation picoCTF 2024 obfuscation browser_webshell_solvable browser

AUTHOR: JEFFERY JOHN

Description

Why search for the flag when I can make a bookmarklet to print it for me?
Browse [here](#), and find the flag!

This challenge launches an instance on demand.
Its current status is: **RUNNING**
Instance Time Remaining: **28:35**

Restart Instance

Hints 

1 2 3

63,134 users solved

 92% Liked 

 picoCTF{p@g3_turn3r_cebccdfe}

Submit Flag

Hurray! You solved this challenge. 

Reflection:

This challenge demonstrated how JavaScript bookmarklets can execute code directly within the browser. By converting the provided script into a bookmarklet, it was possible to run the code that decrypted the hidden flag. The activity highlighted the importance of understanding how client-side scripts and browser tools can be used to analyze and execute embedded code during web security analysis.